

CTI RAG Chatbot: Software Expert Question Answers

CTI RAG Chatbot: Software Expert Question Answers

1. Problem and Objective Understanding

Question: What problem does this project solve?

Answer:

This project solves the problem of slow and unreliable access to cyber threat intelligence. Security analysts often need to find information about MITRE ATT&CK techniques, threat groups, malware, detections, and mitigations very quickly. Manually searching large documents is time-consuming and can miss related context. This chatbot makes that process faster by allowing users to ask natural-language questions and receive grounded answers from MITRE ATT&CK data.

Question: What is the main objective of the paper or project?

Answer:

The main objective is to build a defensive, retrieval-based chatbot for cyber threat intelligence. The system should understand user questions, retrieve the most relevant MITRE ATT&CK documents, generate a clear answer, and avoid hallucinations by only responding from trusted context. It is designed for defensive cybersecurity use, not for offensive misuse.

Question: Why is this problem important?

Answer:

This problem is important because cybersecurity decisions are time-sensitive. In incident response, analysts cannot afford wrong or delayed information. MITRE ATT&CK is also large and constantly updated, so a semantic assistant helps users find the right knowledge faster and more reliably.

2. Dataset and Methodology

Question: What dataset is used?

Answer:

The project uses the MITRE ATT&CK Enterprise dataset in STIX JSON format. The dataset contains objects such as attack-pattern, intrusion-set, malware, tool, and course-of-action. These objects give both structured metadata and descriptive text for retrieval.

Question: How is the data processed?

Answer:

First, the STIX file is loaded from the local data folder or downloaded from MITRE if needed. Then the system filters the relevant CTI object types, extracts metadata such as name, type, ID, and URL, and converts each object into readable text. After that, the text is split into overlapping chunks, embedded with all-MiniLM-L6-v2, and stored in a FAISS vector index.

Question: What method or model approach is used?

Answer:

The project uses Retrieval-Augmented Generation, or RAG. This means the model does not answer from memory alone. Instead, it first retrieves relevant MITRE ATT&CK passages and then uses an LLM to generate an answer based on that retrieved context. The system also includes query rewriting and a

hallucination guard.

Question: Why was this method chosen?

Answer:

RAG was chosen because CTI information changes often and needs source grounding. Traditional machine learning would require labeled training data and retraining, while RAG allows the knowledge base to be updated by re-indexing new data. This makes it better suited for evolving cybersecurity content.

3. Architecture and Workflow

Question: How does the system architecture work?

Answer:

The system has four main layers: the frontend user interface, the Flask backend, the retrieval and generation layer, and the MITRE ATT&CK indexing layer. The frontend sends the user question to the backend. The backend rewrites the question if needed, retrieves the most relevant ATT&CK chunks from FAISS, sends them to the LLM, and then checks whether the answer is grounded before returning it.

Question: What modules are involved?

Answer:

The important modules are the web UI, query rewriting, retrieval with FAISS, LLM response generation, hallucination checking, chat history handling, and the ingestion pipeline that builds the vector index from MITRE ATT&CK data.

Question: What is the step-by-step workflow?

Answer:

1. The user types a CTI question in the web interface.
2. The frontend sends the question to the Flask API.
3. The backend rewrites the question into cybersecurity context if necessary.
4. FAISS retrieves the most relevant MITRE ATT&CK documents.
5. The LLM generates an answer using the retrieved context.
6. The hallucination guard checks whether the answer is supported.
7. The final answer, source list, and context are returned to the user.

4. Results and Critical Analysis

Question: What results does the project report?

Answer:

The repository mainly reports target performance and acceptance criteria rather than a full experimental benchmark table. The documented goals include fast query response, quick retrieval, accurate source grounding, and low hallucination. The SRS also defines expected latency, throughput, and correctness thresholds.

Question: Which model performs best?

Answer:

The primary model is Groq with mixtral-8x7b-32768, because it gives the strongest combination of

speed and answer quality. If Groq is not available, the system can fall back to a local Ollama model for offline operation.

Question: Are the results convincing?

Answer:

The design is convincing because it is logically strong and well suited to CTI. The grounding approach, source citations, and hallucination guard make the answers more trustworthy. However, a stronger paper would include measured evaluation results such as retrieval accuracy, answer correctness, and latency on a test set.

Question: What are the limitations?

Answer:

The main limitations are the lack of a formal benchmark section, dependence on external LLM availability for the cloud model, and the fact that some performance claims are targets rather than measured outcomes. The system is also limited by the quality of the MITRE data and the retrieval step.

5. Learning, Innovation, and Presentation

Question: What is innovative about this project?

Answer:

The innovation is in combining MITRE ATT&CK, semantic retrieval, RAG, defensive query rewriting, and hallucination control into one cybersecurity assistant. The project is not just a chatbot; it is a CTI assistant designed to stay grounded in trusted security documentation.

Question: What improvements or extensions would you suggest?

Answer:

Possible improvements include adding a real evaluation dataset, measuring precision and recall for retrieval, adding confidence scoring, supporting more threat intelligence sources such as CVEs or reports, and building a knowledge graph for deeper relationships between techniques and threat groups.

Question: What are the real-world applications?

Answer:

This system can be used by SOC analysts, incident response teams, threat hunters, purple teams, and cybersecurity students. It can speed up research, improve understanding of attack techniques, and provide auditable answers backed by MITRE sources.

Question: How should I present this in an interview or viva?

Answer:

You should explain the problem first, then describe the MITRE ATT&CK dataset, then describe the RAG pipeline, and finally discuss the benefits and limitations. Keep your explanation clear and defensive in tone. A strong closing line is: this project helps users get faster, safer, and more trustworthy cyber threat intelligence answers.

Short Final Summary

This project builds a defensive cyber threat intelligence chatbot using MITRE ATT&CK data, FAISS retrieval, and an LLM-based RAG pipeline. Its main strengths are semantic search, source grounding,

and hallucination control. Its main weakness is that the documentation shows design targets more clearly than measured experimental results.